

Attest AI

Test Plan and Coverage Specification

Product	Attest AI, AI Safe@Work
Environment	aisafework.netlify.app
Backend	Supabase hanjrsslhnuauaysbhun
Version	1.0
Date	31 Jul 2026
Coverage	8 end to end flows, 204 test cases

Internal document. This plan names security weaknesses, test credentials and unreleased behaviour. It lives in docs/ , which netlify.toml already returns 404 for, so it is not served publicly. Keep it that way.

1. Scope, environment and conventions

1.1 In scope

- **Public marketing site**, 50 root pages plus 29 templates, and every top navigation section.
- **Course**, 11 core modules plus role tracks and sector overlays, quizzes, certificates.
- **Manager portal and Governance Centre**, all 16 sections.
- **End user portal**, progress, certificate, policy acknowledgement.
- **Reseller portal**, deal registration, customers, commissions, marketing materials.
- **Authentication and authorisation**, password, TOTP MFA, magic link, reset, RLS enforcement.
- **Payments**, Stripe Bacs Direct Debit checkout and the fulfilment webhook.
- **Cross cutting**, CSP, caching, SEO and robots posture, accessibility, responsive layout.

1.2 Out of scope

- Supabase, Netlify and Stripe platform internals. We test our use of them, not the vendors.
- Video rendering pipeline in `video-project/`, which is not deployed.
- Internal slide decks, which are known to be broken live by CSP and are parked deliberately.

1.3 Test roles and accounts

Role	Account	Lands on	Notes
Anonymous	none	Public pages only	Must never reach gated content
End user	to be created	<code>course.html</code>	Seated by a manager, consumes one credit
Manager	<code>jcmckenny@gmail.com</code>	<code>portal/manager.html</code>	Provisioned 30 Jul 2026, 0 credits
Reseller	to be created	<code>portal/reseller.html</code>	No reseller exists in the project yet
Demo	<code>demo@attest-ai.com</code>	<code>portal/manager.html</code>	Password is public in a public repo, treat as burned

1.4 Conventions

Every case carries an ID, the steps, and an **expected result** stated in observable terms. A case passes only when the expected result is observed in full. Partial matches fail.

Priority	Meaning
P1	Blocks release. Money, access control, data loss, or a broken primary journey.
P2	Significant defect. A journey works but is degraded, or a secondary feature is broken.
P3	Cosmetic, copy, or nice to have. Log it, do not block on it.

Read section 11 before running anything. Four known platform states will make large parts of this plan fail for reasons that are not defects in the code under test. Sections F, G and the manager and end user flows are all affected. Record those as *Blocked*, not *Failed*.

2. Section A, end to end user flow scenarios

Each flow is a single continuous journey. A flow fails at the first step whose expected result is not met. Run flows before the functional sections, they surface integration defects that per screen testing hides.

A1, Prospect discovers, evaluates and buys Foundation

Persona Operations manager at a 40 person UK firm. **Entry** Organic search or direct. **Goal** Understand the product, confirm it is credible, and pay.

#	Action	Expected result
1	Land on <code>index.html</code>	Hero, the "note on what we are" certification preface, and the Products, Who We Help, Plans nav are visible. No console errors. No CSP violations.
2	Open Who We Help	Seven audience types render, each pairing arrival challenges with the response. The starting point table shows Foundation, Platform and Consultancy. Prices match <code>pricing.html</code> exactly.
3	Open Plans	Foundation £990 (1 to 25) and £1,750 (26 to 50). Platform £249 and £499 per month, billed annually £2,490 and £4,990. Over 50 shows "contact us" for both. Every price says it excludes VAT.
4	Click the course demo video	Video plays from the start. SKIP is absent on first view. On completion the "Buy now" overlay appears on the final frame and points at <code>BUY_URL</code> .
5	Open the free sample, module 1	Module 1 loads without a sign in prompt. It is the only module that does so.
6	Attempt module 2	Redirected to <code>course.html?locked=1</code> . A lock message explains access comes with a plan.
7	Click Order Foundation from the course page	The CTA sits at the end of the Module Breakdown section. It opens <code>checkout.html</code> .
8	Inspect the checkout page	Heading reads "Order Foundation". The what you get card lists seven inclusions. Submit button reads Buy Foundation . A hidden <code>plan</code> field carries "Foundation".
9	Complete the form, band 1 to 25, and submit	With a Stripe key present, the browser navigates to <code>checkout.stripe.com</code> showing £990 and Bacs Direct Debit. Without a key, the page falls back to the Netlify order form and shows the not switched on message.
10	Complete the Bacs mandate on Stripe	Stripe displays the Direct Debit Guarantee. On submit the browser returns to <code>checkout-thanks.html?dd=1</code> .
11	Read the thank you page	The Direct Debit variant shows, stating Bacs takes three to five working days and the payment will show as pending. The invoice wording is hidden.
12	Wait for Bacs settlement	Stripe fires <code>checkout.session.async_payment_succeeded</code> . The webhook creates the buyer, grants 25 credits and promotes them to manager. A row appears in <code>stripe_events</code> .
13	Buyer attempts to sign in	Currently fails. No SMTP means no credential is ever delivered. Record as Blocked against AUTH-1, see section 11.

A2, Manager onboards the organisation and stands up governance

Persona Newly provisioned manager. **Goal** Reach a defensible governance position from empty.

#	Action	Expected result
1	Sign in at <code>portal/login.html</code>	Password accepted, TOTP enrolment is offered because no factor exists. After enrolment the manager lands on <code>manager.html</code> .
2	Open the Governance Centre	Heading reads "Governance Centre". Objectives widget renders at the top. All registers show empty states, not errors.
3	Add a business objective with a past target date	The objective saves and is flagged overdue. Overdue is computed from the date, never stored, so changing the system date changes the flag.
4	Add two AI tools, ChatGPT Enterprise and ChatGPT Personal	Both save as separate rows with different account types. The account type field is the point of the register and must be independently settable.
5	Generate the Acceptable Use Policy	Section 3 is generated from the AI Tool Register and lists both tools with their account types. With an empty register it falls back to the typed list.
6	Publish the policy at v1.0	Status flips to published with today's date. Staff acknowledgement controls become enabled.
7	Add a use case against an unregistered tool	The Governance Centre raises a flag naming the unregistered tool.

8	Add a risk, score likelihood and impact	The matrix places it correctly. Residual risk reads "Not scored" until mitigation is planned, it does not assume the inherent score.
9	Assign an owner from staff records	The owner picker lists staff records. A legacy typed name is retained and displayed as "not a team member".
10	Add staff and publish the announcement	Copy announcement message places text on the clipboard containing the absolute portal sign in URL.
11	Invite a team member	Currently fails. Requires SMTP and a non zero credit balance. Record as Blocked.
12	Reload the browser	Every register, the policy and the objectives persist, having been read back from Supabase and not from <code>localStorage</code> . See NEG-DB-01.

A3, End user completes the course and earns a certificate

#	Action	Expected result
1	Open the invite link and set a credential	Magic link authenticates and routes to <code>course.html</code> , the staff landing page.
2	Open module 1 and read to the end	Content renders, the quiz appears at the end of the module.
3	Answer the quiz scoring below 80 per cent	Result shows as not passed. No row is written to <code>module_progress</code> . The user may retry.
4	Retake and score 80 per cent or above	Pass. A row is inserted in <code>module_progress</code> with the score and an <code>module_completed</code> audit entry is written.
5	Retake again and score lower	The stored score does not decrease. <code>record_quiz_result</code> keeps the greatest score.
6	Complete all 11 core modules	The printable checklist unlocks. Progress shows 11 of 11 on the end user portal.
7	Generate the certificate	<code>cert.html</code> renders with the learner name, module and score, and prints cleanly to one page.
8	Manager checks completion	The manager sees this user's completion in the Team pane and in the completion CSV export.

A4, Reseller registers and converts a deal

#	Action	Expected result
1	Sign in as reseller	Password plus TOTP, then lands on <code>reseller.html</code> . A manager or end user URL redirects back to their own dashboard.
2	Open the dashboard	Deals, customers and commissions render, scoped to this reseller only.
3	Register a deal	Row is created at stage <code>registered</code> with the reseller as owner. It appears immediately.
4	Move the deal to qualified, then won	Stage transitions persist. Only the four permitted stages are accepted.
5	Check commissions	Commissions are read only. The reseller cannot create or edit a commission, statements are issued by admin.
6	Open partner commercials	Rebate tiers, wholesale per seat and margins render inside the portal. They must not appear on any public page.
7	Download marketing materials	Share card, pitch deck and standards map all download or open without a 404.

A5, Staff policy acknowledgement rollout

#	Action	Expected result
1	Manager publishes the AUP at v1.0	Version and published date shown. Acknowledgement control enabled.
2	Manager copies the announcement	Clipboard text names the version, the company, the DPO and incident contact, and contains the absolute sign in URL.
3	Manager sends a per person reminder	The mail client opens with a subject, a greeting using the staff name, the policy version and the sign in URL in the body.
4	Staff member opens the link and signs in	Routed to the end user surface, not the manager portal.
5	Staff member acknowledges the policy	The acknowledgement is recorded against the current version.
6	Manager checks the roster	Known gap. The roster reads acknowledgements from <code>governance_state</code> while the end user portal writes <code>governance_acks</code> . The two are not linked, so the roster may still read "Not yet". Record against the open decision in section 11.
7	Manager republishes at v1.1	Prior acknowledgements no longer satisfy the current version. Staff show as outstanding again.

A6, MSP partner enquiry

#	Action	Expected result
1	Click Become a Partner	<code>msp.html</code> loads. It carries <code>noindex</code> by choice and is absent from <code>sitemap.xml</code> .
2	Submit the partner enquiry form	POST to the <code>partner-enquiry</code> Netlify form returns 200 and lands on the thank you page.
3	Check for notification	Currently fails. No form notification is configured, so nobody is told. Record as Blocked against 0a.

A7, Demo and evaluation without an account

#	Action	Expected result
1	Open <code>portal/demo.html</code> from pricing	The full platform renders with sample data and no sign in. Path detection puts it in demo mode.
2	Add a register row and reload	Data is held in <code>sessionStorage</code> , nothing is written to Supabase.
3	Close the tab and reopen	All demo edits are gone. Sample data is reseeded.
4	Attempt to reach real data from demo	No request carries a real user session. No row in any Supabase table is created or modified.

A8, Book a demo

#	Action	Expected result
1	Click Book a Demo	Navigates to <code>about.html#contact</code> and scrolls to the contact section.
2	Submit the demo form	POST to the <code>demo</code> form returns 200, redirects to <code>demo-thanks.html</code> .
3	Submit with a honeypot value filled	Netlify silently discards it. No submission appears in the dashboard.

3. Section B, public site by navigation area

B1, Global navigation and shell

ID	Test	Steps and expected result	Pri
NAV-01	Nav present site wide	Load each of the 50 root pages. Expected Products, Who We Help, Plans, Sign in, Book a Demo and Become a Partner appear on every one.	P1
NAV-02	Centring above 901px	Set viewport 1280px. Expected Nav is centred using the three column grid, on one row.	P2
NAV-03	Wrap below 901px	Set viewport 900px. Expected Nav wraps to a second row. No pill is clipped or crushed to a disc.	P1
NAV-04	Narrow viewport overflow	Set viewport 390px. Expected Top bar fits without horizontal scroll. The theme toggle remains on screen. This regressed once at 457px required width.	P1
NAV-05	Tablet width	Set viewport 768px. Expected No horizontal overflow, all pills reachable.	P1
NAV-06	Every nav target resolves	Click each nav item. Expected HTTP 200 on all six, no redirect chain, no 404.	P1
NAV-07	Products anchor	Click Products. Expected Lands on <code>index.html#how-we-help</code> and scrolls to that section.	P2
NAV-08	Skip link	Tab once from page load. Expected "Skip to main content" receives focus, is visible, and jumps to <code>#main</code> .	P2
NAV-09	Theme toggle persists	Switch to dark, reload. Expected Dark persists via <code>localStorage</code> key <code>aisw-theme</code> , with no flash of light theme.	P2
NAV-10	Footer integrity	Check footer on ten pages. Expected Plans, Services, Resources and Company columns present, every link 200.	P2
NAV-11	Module bottom nav	On course and checkout pages. Expected Back and next controls resolve to real pages.	P3

B2, Home

ID	Test	Steps and expected result	Pri
HOME-01	Certification preface	Read the "note on what we are". Expected Present, and states Attest AI is not a certification or accreditation body.	P1
HOME-02	Audit ready wording	Search the page for "audit ready". Expected Every use means records organised the way an auditor asks. No instance implies a guaranteed pass.	P1
HOME-03	JSON-LD parses	Extract every <code>application/ld+json</code> block. Expected All parse. The pre-push guard enforces this, so a failure here means the guard was bypassed.	P1
HOME-04	No em dashes	Grep rendered text for the em dash character. Expected None. House style is comma when spaced, hyphen when not.	P3

B3, Who We Help

ID	Test	Steps and expected result	Pri
WWH-01	Seven audiences	Count audience blocks. Expected Seven, each pairing arrival challenges with the response.	P2
WWH-02	Starting point table	Read the table. Expected Foundation, Platform and Consultancy each have a starting point.	P2
WWH-03	Price parity	Compare every price against <code>pricing.html</code> . Expected Identical. Prices are pulled, not restated.	P1
WWH-04	Sector overlays reachable	Click the three regulated sector links. Expected Healthcare, financial services and public sector all load. They are otherwise orphaned.	P2

B4, Plans and pricing

ID	Test	Steps and expected result	Pri
PRC-01	Foundation bands	Expected £990 for 1 to 25, £1,750 for 26 to 50, contact us above 50.	P1
PRC-02	Platform bands	Expected £249 and £499 per month, billed annually £2,490 and £4,990, contact us above 50.	P1
PRC-03	VAT statement	Expected Every price is marked as excluding VAT.	P1

PRC-04	Band price held	Expected The twelve month price hold is stated.	P2
PRC-05	Offer schema matches	Parse the Offer JSON-LD. Expected Values equal the visible prices. A mismatch misprices the product in search results.	P1
PRC-06	Retired tier numbers	Search for "Tier 1", "Tier 2", "Tier 3". Expected None. Tier numbering was retired site wide.	P2
PRC-07	Robots contradiction	Compare the page meta, sitemap.xml and the X-Robots-Tag header. Expected once resolved All three agree. Today They do not, see section 11.	P1
PRC-08	Platform demo link	Click the demo button. Expected Opens the platform demo, which renders without a sign in.	P2

B5, Course and learning content

ID	Test	Steps and expected result	Pri
CRS-01	Section navigation	Click Overview, Learning Outcomes, Module Breakdown. Expected Each scrolls to its section.	P2
CRS-02	Order CTA placement	Expected The Order Foundation CTA sits inside the Module Breakdown section, after the final module card.	P2
CRS-03	Eleven modules listed	Count module cards. Expected Eleven plus the standards reference card. Copy says "eleven working modules", never "sections".	P2
CRS-04	Module 1 is public	Open module 1 signed out. Expected Loads. It is the free sample.	P1
CRS-05	Modules 2 to 12 gated	Open each signed out. Expected All redirect to course.html?locked=1.	P1
CRS-06	Role tracks gated	Open the manager, DPO, procurement, MSP admin, Copilot and shadow AI modules signed out. Expected All redirect.	P1
CRS-07	Sector overlays gated	Open the three sector pages signed out. Expected Redirect to checkout.html.	P1
CRS-08	Public reference pages	Open glossary, standards map and resources signed out. Expected All load. These were deliberately ungated.	P2
CRS-09	Preview overlay	Click the CTA carrying data-course-preview. Expected The preview opens by delegated event, not an inline handler, and survives the production CSP.	P1

B6, Quizzes and certificates

ID	Test	Steps and expected result	Pri
QUIZ-01	Pass mark is 80	Score exactly 79 per cent, then exactly 80. Expected 79 fails, 80 passes. The threshold is enforced in record_quiz_result, not the browser.	P1
QUIZ-02	Answers never sent	Inspect the network response for the quiz. Expected The correct answers are not present in any payload. Scoring happens against quiz_keys server side.	P1
QUIZ-03	Fail writes nothing	Fail a quiz, query module_progress. Expected No row for that module.	P1
QUIZ-04	Best score retained	Pass at 100, retake at 80. Expected Stored score stays 100.	P2
QUIZ-05	Audit entry written	Pass a module, query audit_log. Expected A module_completed entry with module, score and total.	P2
QUIZ-06	Certificate renders	Open cert.html after passing. Expected Name, module and score render and print to a single page.	P2

B7, Forms

ID	Test	Steps and expected result	Pri
FRM-01	Three forms registered	POST to order, demo, partner-enquiry. Expected All return 200.	P1
FRM-02	Unknown form rejected	POST to a name that does not exist. Expected 404, proving detection is discriminating.	P2
FRM-03	Orphaned forms removed	POST to tier1-order and foundation-order. Expected once cleaned 404. Today 200, which drops orders into a form nobody watches.	P1
FRM-04	Required fields	Submit each form empty. Expected Native validation blocks submission and focuses the first invalid field.	P2
FRM-05	Email format	Enter notanemail. Expected Rejected before submission.	P2
FRM-06	Headcount required	Submit the order form with no band. Expected Blocked, the select is required.	P1

FRM-07	Notification delivered	Submit a live order. Expected once configured An email reaches James@attest-ai.com. Today Nothing is sent.	P1
--------	------------------------	---	----

4. Section C, manager portal and Governance Centre

Sixteen sections. Unless stated, every case runs as an authenticated manager with a populated organisation, and every persistence check requires a full page reload.

C1, Governance Centre, the dashboard

ID	Test	Steps and expected result	Pri
G0V-01	Naming	Expected Nav item, heading and every in product guide say "Governance Centre", never "Dashboard".	P3
G0V-02	Objectives widget	Expected Renders at the top of the Governance Centre.	P2
G0V-03	Overdue is computed	Set a target date in the past. Expected Flagged overdue. Change the date to the future, the flag clears without any stored field changing.	P2
G0V-04	Flag, unregistered tool	Create a use case naming a tool absent from the register. Expected Flag raised naming the tool.	P1
G0V-05	Flag, restricted tool	Create a use case on a tool marked restricted or not approved. Expected Flag raised.	P1
G0V-06	Flag, awaiting decision	Leave a tool undecided. Expected Flag raised.	P2
G0V-07	Flag, past review	Set a review date in the past. Expected Flag raised.	P2
G0V-08	Flag, approved with no owner	Approve a tool, leave the owner empty. Expected Flag raised.	P2
G0V-09	No unapproved AI count	Inspect the Centre. Expected No "N users using unapproved AI" metric anywhere. The platform cannot source it and must not imply it can.	P1
G0V-10	Empty organisation	Sign in as a manager with nothing configured. Expected Empty states everywhere, no errors, no NaN, no "undefined".	P1

C2 to C12, the registers

ID	Test	Steps and expected result	Pri
AUP-01	Generate policy	Expected A complete policy is produced from current data.	P1
AUP-02	Section 3 from register	Populate the AI Tool Register, regenerate. Expected Section 3 lists the registered tools with account types.	P1
AUP-03	Section 3 fallback	Empty the register, regenerate. Expected Falls back to the typed list rather than producing an empty section.	P1
AUP-04	Publish and version	Publish. Expected Version and published date shown, acknowledgement enabled.	P1
AUP-05	Unpublished blocks ack	Leave in draft. Expected The acknowledge button is disabled and a message says the policy must be published first.	P1
AUP-06	Version supersedes acks	Publish v1.1 after acknowledgements at v1.0. Expected Prior acks no longer count as current.	P1
T00L-01	Account type independent	Add the same product twice with different account types. Expected Two distinct rows, independently decidable.	P1
T00L-02	Decision lifecycle	Move a tool through undecided, approved, restricted. Expected Each state persists and drives the correct Centre flag.	P2
T00L-03	Owner from staff	Set the decision owner. Expected The picker offers staff records. A legacy typed name is preserved and shown as "not a team member".	P2
UC-01	Create use case	Expected Saves, appears in the register, and links to its tool.	P2
UC-02	Owner references staff	Expected Owner picker lists staff records.	P2
RISK-01	Matrix placement	Set likelihood and impact. Expected The risk lands in the correct matrix cell.	P2
RISK-02	Residual not assumed	Leave mitigation unplanned. Expected Residual risk reads "Not scored". It must not default to the inherent score.	P1
RISK-03	Residual after mitigation	Plan mitigation and score residual. Expected Same matrix, new position.	P2
RISK-04	Risk owner	Expected Owner references staff records.	P2
ASS-01	Assessment sets rating	Complete an assessment. Expected The use case rating is set automatically from the answers.	P1
VEN-01	Due diligence record	Create a vendor record. Expected Saves and appears.	P2

VEN-02	Two front doors	Compare Vendor Due Diligence with the AI Tool Register. Expected Both exist. The tool register serves tools with no supplier to send diligence to.	P2
VRS-01	Vendor risk score	Expected Score derives from the diligence answers and updates when they change.	P2
INC-01	Incident lifecycle	Raise, update and close an incident. Expected Each state persists.	P2
RACI-01	Roles matrix	Assign R, A, C and I. Expected Assignments persist and render.	P3
TOR-01	Steering group ToR	Complete and save. Expected Persists and exports.	P3
STF-01	Roster CRUD	Add, edit and remove staff. Expected All persist.	P2
STF-02	Announcement carries link	Click Copy announcement message. Expected Clipboard text contains the absolute portal sign in URL, the version, the company, the DPO and the incident contact.	P1
STF-03	Reminder carries link	Click Email reminder. Expected Mail client opens with the staff name, the version and the sign in URL.	P2
STF-04	No artifact language	Read all copy on the screen. Expected No reference to "this artifact", "share / publish above the conversation", or acknowledgements appearing "instantly for everyone".	P2

C13 to C16, the Manage group

ID	Test	Steps and expected result	Pri
TEAM-01	Invite a seat	Invite with credits available. Expected One credit is spent, the account is created and seated, and the invitee is emailed.	P1
TEAM-02	Invite with zero credits	Invite at balance 0. Expected Refused with "no credits remaining". No account is created, no credit goes negative.	P1
TEAM-03	Duplicate seat	Invite the same person twice. Expected Second attempt fails with "seat already assigned" and does not spend a credit.	P1
TEAM-04	Cross tenant seat	Invite someone already managed by another manager. Expected Refused with "user is managed by another account".	P1
TEAM-05	Remove a seat	Remove a seated user. Expected The seat is removed and the roster updates.	P2
TEAM-06	Demo blocked from invite	Invite while signed in as the demo account. Expected Blocked as anti spam.	P2
CRS-M-01	Completion visibility	Expected The manager sees completion only for their own seated users.	P1
CRS-M-02	Completion CSV	Export. Expected CSV downloads, contains only seated users, and opens cleanly in a spreadsheet.	P2
TPL-01	Templates available	Expected All 27 templates open or download without a 404.	P2
UPD-01	Updates pane	Expected Renders the changelog without error.	P3

5. Section D and E, end user and reseller portals

D, End user portal

ID	Test	Steps and expected result	Pri
EU-01	Landing	Sign in as end user. Expected Routed to <code>course.html</code> , which is what they signed in to do.	P1
EU-02	Own progress only	Open the progress view. Expected Only this user's modules appear.	P1
EU-03	Certificate access	Expected Reachable once the core is complete.	P2
EU-04	Governance documents	Expected Reads <code>governance_docs</code> for the current published policy.	P2
EU-05	Acknowledge policy	Acknowledge. Expected A row is written to <code>governance_acks</code> against the current version.	P1
EU-06	Manager pages refused	Navigate directly to <code>manager.html</code> . Expected Redirected to the end user destination, no manager data renders even briefly.	P1
EU-07	Reseller pages refused	Navigate to <code>reseller.html</code> . Expected Redirected.	P1

E, Reseller portal

ID	Test	Steps and expected result	Pri
RS-01	Landing	Expected Routed to <code>reseller.html</code> .	P1
RS-02	Deal registration	Register a deal. Expected Created at stage <code>registered</code> , owned by this reseller.	P1
RS-03	Stage constraint	Attempt a stage outside registered, qualified, won, lost. Expected Rejected by the check constraint.	P2
RS-04	Own deals only	Query <code>deal_registrations</code> as this reseller. Expected Only their own rows return.	P1
RS-05	Commissions read only	Attempt to insert or update a commission. Expected Refused. Statements are issued by admin.	P1
RS-06	Commercials stay private	Search the public site for rebate tiers, wholesale per seat and margins. Expected Absent from every public page, present only behind the portal login.	P1
RS-07	Marketing materials	Open share card, pitch deck and standards map. Expected All resolve.	P2
RS-08	Manager pages refused	Navigate to <code>manager.html</code> . Expected Redirected.	P1

6. Section F, authentication and authorisation

ID	Test	Steps and expected result	Pri
AUTH-01	Password sign in	Correct credentials. Expected Session established, routed by role.	P1
AUTH-02	Wrong password	Expected Refused, with a message that does not reveal whether the address exists.	P1
AUTH-03	TOTP enrolment	First sign in as manager with no factor. Expected Enrolment is offered and completes.	P1
AUTH-04	TOTP challenge	Sign in with a factor enrolled. Expected Challenged. Access is refused until it is satisfied.	P1
AUTH-05	AAL2 enforced	Enrol a factor, then reach a portal page without completing the challenge. Expected Treated as not authenticated.	P1
AUTH-06	Wrong TOTP code	Expected Refused, no session upgrade.	P1
AUTH-07	Magic link for staff	Request a link as an end user. Expected Email arrives, the link authenticates and routes to the course.	P1
AUTH-08	Reset lands on reset	Follow a recovery link. Expected The set new password form is shown and stays shown. Both the implicit <code>#type=recovery</code> and PKCE <code>?code=</code> callbacks must be classified correctly.	P1
AUTH-09	Reset completes	Set a new password. Expected Sign in with the new password succeeds, the old one fails.	P1
AUTH-10	Open redirect refused	Sign in with <code>?next=//evil.example</code> . Expected Ignored. Only same origin paths beginning with a single slash are honoured.	P1
AUTH-11	Sign out clears	Sign out, then press back. Expected No portal data renders, the session is gone.	P1
AUTH-12	Sign up is closed	Attempt self service registration. Expected No path exists. Accounts come from purchase or invitation.	P1
RLS-01	Read own profile only	Query <code>profiles</code> as an authenticated user. Expected Only their own row, plus seated end users if a manager.	P1
RLS-02	Self escalation refused	PATCH your own <code>role</code> to manager. Expected 403. Column grants allow <code>full_name</code> only.	P1
RLS-03	Self credit grant refused	PATCH your own <code>credits_balance</code> . Expected 403.	P1
RLS-04	Mass assign refused	PATCH several columns at once including <code>full_name</code> . Expected 403, not a partial write.	P1
RLS-05	IDOR refused	PATCH another user's profile by id. Expected Zero rows affected.	P1
RLS-06	Direct seat insert refused	INSERT into <code>seats</code> directly. Expected Refused. Seats come only from <code>assign_seat</code> , which checks credits.	P1
RLS-07	Non manager cannot seat	Call <code>assign_seat</code> as an end user. Expected "only managers can assign seats".	P1
RLS-08	Cross tenant progress	Read <code>module_progress</code> for a user seated elsewhere. Expected No rows.	P1
RLS-09	<code>grant_credits</code> is privileged	Call <code>grant_credits</code> as an authenticated manager. Expected Refused. Only the service role and admin may call it.	P1
RLS-10	Negative credit refused	Call <code>grant_credits</code> with a negative or zero amount. Expected "amount must be positive".	P1
RLS-11	Reseller not demoted	<code>grant_credits</code> against a reseller. Expected Credits added, role stays <code>reseller</code> .	P2
RLS-12	Privilege change audited	Change a role or credit balance. Expected An <code>audit_log</code> entry records old and new values.	P2

7. Section G, payments

ID	Test	Steps and expected result	Pri
PAY-01	Foundation 1 to 25	Submit the band. Expected Stripe session for £990 by Bacs, GBP.	P1
PAY-02	Foundation 26 to 50	Expected Stripe session for £1,750.	P1
PAY-03	Over 50 falls through	Select the quote band. Expected No Stripe session. The Netlify order form submits as before.	P1
PAY-04	Platform must not price as Foundation	Open <code>checkout.html?plan=platform</code> , select 1 to 25, submit. Expected No Stripe session at the Foundation price. This is the regression that shipped once and was caught before any key existed.	P1
PAY-05	Server owns the price	POST a forged <code>unit_amount</code> or an unknown band to the function. Expected Ignored or refused. The browser never supplies an amount.	P1
PAY-06	Missing plan refused	POST with no <code>plan</code> . Expected Refused.	P1
PAY-07	Plan match is exact	POST <code>plan=foundation</code> in lower case. Expected Refused. The match is exact by design.	P2
PAY-08	Invalid email refused	POST a malformed address. Expected 400 before any Stripe call.	P1
PAY-09	VAT applied	Set <code>VAT_RATE=0.20</code> . Expected £990 becomes £1,188 at Stripe. Unset charges £990.	P1
PAY-10	No key falls back	Unset <code>STRIPE_SECRET_KEY</code> . Expected Function returns 503, the page submits the order form and explains payment is not switched on. The button is never dead.	P1
PAY-11	Network failure falls back	Block the function in devtools. Expected Same graceful fallback.	P2
PAY-12	Cancel returns	Cancel at Stripe. Expected Returns to <code>checkout.html</code> with nothing charged.	P2
PAY-13	Method is GET refused	GET the function. Expected 405.	P3
H00K-01	Valid signature accepted	Send a correctly signed event. Expected Processed, 200.	P1
H00K-02	Forged payload refused	Send unsigned or wrongly signed JSON. Expected 400, nothing provisioned. This is the attack that would otherwise grant free credits.	P1
H00K-03	Replay refused	Replay a genuine delivery older than five minutes. Expected 400.	P1
H00K-04	Secret rotation	Send a delivery carrying two <code>v1</code> signatures, one current. Expected Accepted.	P2
H00K-05	Bacs waits for settlement	Send <code>checkout.session.completed</code> with <code>payment_status</code> not paid. Expected Ignored, nothing provisioned. Access must not precede cleared funds.	P1
H00K-06	Settlement provisions	Send <code>async_payment_succeeded</code> . Expected Buyer created, promoted to manager, credits granted to match the band.	P1
H00K-07	Duplicate delivery	Send the same event id twice. Expected Provisioned once. Credits are not doubled.	P1
H00K-08	Retry after failure	Force a mid provision failure, then let Stripe retry. Expected The retry provisions successfully. The claimed event id was released on failure.	P1
H00K-09	Existing buyer	Send a settlement for an address that already has an account. Expected No duplicate account, credits added to the existing one.	P1
H00K-10	Unconfigured	Unset the keys. Expected 503, nothing attempted.	P2

8. Section H, cross cutting

H1, Content security policy

ID	Test	Steps and expected result	Pri
CSP-01	No violations on live	Load every page on the deployed site with the console open. Expected Zero CSP violations. Local testing will not catch these, production sends <code>script-src 'self'</code> .	P1
CSP-02	No inline handlers	Grep the deployed HTML for <code>onclick=</code> . Expected None in shipped pages. Actions go through the <code>data-act</code> dispatcher.	P1
CSP-03	Portal connect-src	Load the portal. Expected Supabase calls succeed, permitted by the portal specific CSP.	P1
CSP-04	No external scripts on marketing pages	Expected No CDN script loads outside the portal.	P1

H2, Headers, caching and exposure

ID	Test	Steps and expected result	Pri
HDR-01	Portal not cached	Request a portal page. Expected <code>Cache-Control: private, no-store</code> .	P1
HDR-02	Portal not indexed	Expected <code>X-Robots-Tag</code> includes <code>noindex</code> and <code>nofollow</code> .	P1
EXP-01	Internal paths blocked	Request <code>/docs/</code> , <code>/specs/</code> , <code>/supabase/</code> , <code>/tests/</code> , <code>/scripts/</code> , <code>/netlify/</code> , <code>/.audit/</code> . Expected 404 on every one. Netlify publishes the whole repo, so anything not blocked ships.	P1
EXP-02	Named files blocked	Request <code>HANDOFF.md</code> , <code>SCOPE.md</code> , <code>DOCTRINE.md</code> , <code>README.md</code> , <code>skills-lock.json</code> , the MSP deck and the course Word file. Expected 404 on every one.	P1
EXP-03	Function source blocked	Request the <code>.mjs</code> source of both functions. Expected 404, while <code>/.netlify/functions/*</code> still responds.	P1
EXP-04	New internal files	Add a file to an internal directory and deploy. Expected It 404s. If it serves, the rule was never added.	P1
EXP-05	Deliberately public	Request <code>LICENSE*</code> , <code>changelog.json</code> and <code>assets/video/*</code> . Expected 200. These are public by decision.	P2

H3, SEO and robots

ID	Test	Steps and expected result	Pri
SE0-01	Sitemap accuracy	Fetch every URL in <code>sitemap.xml</code> . Expected All 200, all genuinely public, none carrying <code>noindex</code> .	P1
SE0-02	Gated pages noindex	Expected Every gated page carries <code>noindex</code> , so crawlers are never sent to a checkout redirect.	P1
SE0-03	Header and meta agree	For each page compare meta robots with the <code>X-Robots-Tag</code> . Expected No page is told to index by one and noindex by the other.	P1
SE0-04	Canonicals	Expected Each page has one canonical, pointing at the intended host.	P2
SE0-05	Cite friendly paths	Expected Public free core paths carry no <code>noai</code> header.	P3

H4, Accessibility and responsive

ID	Test	Steps and expected result	Pri
A11Y-01	Keyboard only	Complete flows A1 and A3 without a mouse. Expected Every control reachable and operable, focus always visible.	P1
A11Y-02	Form labels	Expected Every input has a programmatic label.	P1
A11Y-03	Status announcements	Trigger the checkout status line. Expected Announced by a screen reader via the live region.	P2
A11Y-04	Heading order	Expected One h1 per page, no skipped levels.	P2
A11Y-05	Contrast	Expected Text meets WCAG AA in both themes.	P2
A11Y-06	The chain degrades	Disable CSS on the Platform page. Expected The eleven step chain still reads in order, it is an ordered list.	P2

RSP-01	No horizontal scroll	At 320, 390, 768, 1024 and 1440px on ten pages. Expected None.	P1
RSP-02	Module grid	Narrow the viewport. Expected The grid reflows, its 300px floor does not force overflow.	P2
RSP-03	Tables on mobile	Expected Portal tables scroll inside their own container, the page body does not.	P2

9. Section I, negative and edge cases

Consolidated adversarial cases. Several encode defects already known to exist.

ID	Test	Steps and expected result	Pri
NEG-DB-01	Permission denial must not look empty	Break an RLS policy deliberately, then load the Governance Centre. Expected A visible error. Known defect dbGet swallows the error and falls back to <code>localStorage</code> , so a denial is indistinguishable from an empty register and a customer's governance data quietly moves into their own browser. Fix before any feature depends on who can read what.	P1
NEG-CERT-01	Certificate forgery	Open <code>cert.html?m=1&s=99&n=100</code> without ever taking the quiz. Expected Refused or clearly marked unverified. Risk The certificate is driven by query parameters, so a learner can mint evidence of a pass they never earned. This matters because the certificate is sold as EU AI Act Article 4 literacy evidence.	P1
NEG-GATE-01	Gate is client side	Disable JavaScript, or delete the gate script, then request a paid module. Expected today The content loads, because the gate is client side only and a static site cannot enforce otherwise. Confirms the documented ceiling. Move content behind an edge function before this protects real revenue.	P1
NEG-GATE-02	Forged session token	Write an arbitrary value into the Supabase auth key in <code>localStorage</code> , then open a gated page. Expected The gate must not accept a token it has not validated.	P1
NEG-GATE-03	Demo cannot read paid content	Sign in as the demo account and open a paid module. Expected Redirected. The demo account is excluded by design.	P1
NEG-AUTH-01	Public demo password	Sign in with the demo credentials taken from the public repository. Expected once armed Refused, the account is rotated or deleted. Today It succeeds, and anyone in the world can reach a manager portal.	P1
NEG-AUTH-02	Real user lands in demo	With no session, open <code>portal/manager.html</code> as a real customer. Expected once armed Bounced to sign in. Today Silently signed in as the demo account, so anything typed becomes world readable.	P1
NEG-XSS-01	Script injection in registers	Enter <code></code> as a tool name, risk title, staff name and company name. Expected Rendered as text, never executed, in the screen, the generated policy and the CSV export.	P1
NEG-XSS-02	Injection via Stripe metadata	Submit a company name containing HTML at checkout. Expected Escaped wherever it is later displayed.	P2
NEG-CSV-01	CSV formula injection	Set a staff name to <code>=cmd' '/c calc'!A1</code> and export. Expected Neutralised so a spreadsheet does not execute it.	P2
NEG-IN-01	Oversized input	Paste 100,000 characters into a register field. Expected Rejected or truncated with a message. No hang, no unbounded write.	P2
NEG-IN-02	Unicode and emoji	Enter emoji, right to left text and combining characters. Expected Stored and rendered correctly, no mojibake in the PDF or CSV export.	P3
NEG-IN-03	Whitespace only	Submit fields containing only spaces. Expected Treated as empty and rejected where required.	P2
NEG-IN-04	Date boundaries	Enter a target date far in the past and far in the future. Expected Handled without breaking the overdue calculation.	P2
NEG-NET-01	Offline mid edit	Drop the network while saving a register row. Expected A clear failure message. The user is never told data is saved when it is not.	P1
NEG-NET-02	Session expiry mid edit	Let the session expire, then save. Expected Prompted to sign in again, the edit is not silently lost.	P1
NEG-CON-01	Concurrent managers	Two sessions edit the same register simultaneously. Expected Defined behaviour, last write wins or a conflict message, never a merged corruption.	P2
NEG-CON-02	Double submit	Double click Buy Foundation. Expected One session created. The button disables on first click.	P1
NEG-BR-01	Back button after payment	Press back from the thank you page. Expected No second charge, no duplicate order.	P1
NEG-BR-02	Deep link while signed out	Open a deep portal URL with no session. Expected Sign in, then return to the requested page, with no flash of portal data.	P1
NEG-SCH-01	Schema reproducibility	Restore the database from <code>supabase/migrations/</code> alone. Expected A working system. Known defect <code>governance_state</code> is in no migration, so the entire manager portal lives in a table the repository cannot reproduce.	P1
NEG-SCH-02	Edge function reproducibility	Redeploy from the repository alone. Expected <code>invite-seat</code> exists. Known defect Its source is not in the repository.	P1

10. Execution and automation

10.1 What already runs

Command	Covers
<code>node tests/checkout-pricing.mjs</code>	PAY-01 to PAY-07, 12 assertions including the Platform band regression
<code>node tests/stripe-webhook.sig.mjs</code>	HOOK-01 to HOOK-04, 9 assertions including a forged payload and a replay
<code>node tests/manager-dashboard.structure.mjs <url></code>	Governance Centre structure
<code>node tests/manager-dashboard.crud.mjs <url></code>	Register create, read, update and delete
Pre-push guard	HOME-03 JSON-LD parsing, secret sweep, forbidden files

Playwright is not installed in this repository by design. The dashboard tests borrow it from a sibling project via `createRequire`, which has broken once already. Reinstall it in a scratch directory or expect those two to fail for environmental reasons.

10.2 Recommended automation order

1. **Section G and the RLS block.** Money and access control, cheap to assert, catastrophic to get wrong. Mostly automatable without a browser.
2. **EXP-01 to EXP-05.** A handful of `curl` calls checking status codes. Should run on every deploy, because Netlify publishes the whole repository.
3. **Flows A1 and A3.** The two journeys that earn and deliver.
4. **Section C.** Highest surface area, slowest to automate, best value from the existing Playwright suite.

10.3 Entry and exit

Entry A deploy is green, the four blockers in section 11 are either resolved or explicitly accepted as Blocked, and test accounts exist for all three roles.

Exit Every P1 passes or has a written, accepted waiver. No P1 defect is open. Every P2 is triaged. Flows A1 to A5 complete end to end without a workaround.

11. Known blockers, expected failures today

These are platform states, not defects in the code under test. Record affected cases as **Blocked**. Running the plan without reading this will produce a long list of misleading failures.

Ref	State	Effect on this plan
A2	<code>AUTH_DISABLED = true</code>	The portal auto signs in as the demo account, and the sign in form is bypassed entirely. Blocks all of section F, flows A2 to A5, and every manager and end user case needing a real identity. Also blocks NEG-AUTH-01 and 02, which describe the risk it creates.
AUTH-1	No custom SMTP	No invite, magic link or reset email is delivered. Blocks AUTH-07 to AUTH-09, TEAM-01, and steps 11 to 13 of flows A1 and A2.
B1	No Stripe account or keys	Both functions return 503 by design. Blocks the live half of section G. The unit tests still cover the logic.
0a	No form notifications	Submissions reach the dashboard but nobody is told. Blocks FRM-07 and step 3 of flow A6.

11.1 Open decisions that change expected results

Decision	Why the expected result cannot be fixed yet
Which acknowledgement store is authoritative	The manager roster reads <code>governance_state</code> , the end user portal writes <code>governance_acks</code> , and nothing links them. Step 6 of flow A5 has no correct expected result until this is decided.
Staff cannot open the sign off page	The acknowledgement panel expects staff on a page that <code>guard(["manager"])</code> refuses them. Inherited from the artifact this screen was ported from.
<code>pricing.html</code> robots contradiction	Meta says index, the sitemap lists it, the header says noindex. PRC-07 and SEO-03 cannot both pass until one of the three changes.
VAT registration status	PAY-09 cannot assert a figure until it is known whether VAT is charged. <code>VAT_RATE</code> is currently unset, so the advertised ex VAT price is taken as is.
Platform has no online payment path	PAY-04 asserts it must not price as Foundation. If Platform is later sold online it needs subscription mode and its own cases.

Coverage summary. 8 end to end flows and 204 test cases, of which 126 are P1, 69 P2 and 9 P3. Seven cases encode defects already known and logged rather than hypothetical ones: NEG-DB-01, NEG-CERT-01, NEG-GATE-01, NEG-AUTH-01, NEG-AUTH-02, NEG-SCH-01 and NEG-SCH-02.

The two states that block the most ground are **A2** and **AUTH-1**. Between them they hold down the whole of section F, four of the eight flows, and every case that needs a real identity rather than the shared demo account. Clearing those two is the single highest leverage action available before this plan can be run in full.